

BDSH Zen map (Nmap GUI) Report – SOIT network.

This is an example report for a network analysis from a team member of BDSH and does not include any AI analysis.

Contents

Summary report.....	1
Description of the network.....	2
Findings	2
Port 22.....	2
Port 23.....	2
Port 443	3
Port 53.....	3
Port 445 and Port 139	3
Port 3389	4
Port 3306	4
Figure #1 - Table of Hosts and Associated Common Vulnerable Ports.	5
Figure #1 - Network topology.....	6
References	6

Summary report

This report contains is an analysis on the SOIT network, it contains a description of the network, Potential vulnerabilities, a List of the Hosts on the network and a network topology for visualising the network. From this analysis we decided that there are vulnerable ports on many hosts in the network, these being port 22, 23, 443, 53, 445, 139, 3389 and 3306. Our recommendation is that these ports be closed if they are not crucial to operation, or Password strength should be increased to reduce the likelihood of brute-force attacks

Description of the network

This network is the school of IT network system and looks to be the server room that operates on level 6 at Whitireia Weltec, this is known due to prior knowledge of the campus. There looks 256 IP addresses with 38 hosts up, on this network there appears to be two routers, one firewall and a number of hosts, as well as sixteen hosts with filtered ports, as evidenced by figure #1 network topology which shows the topology of the school network that we have scanned. Given the network topology of this network, we can tell that this might not be a network that students would be connecting their personal devices on because there are no Wireless Access Points.

Findings

For the machines on this network there are a few ports open that can be exploited, these vulnerable ports are generally Ports 22, 23, 443, 53, 445, 139, 3389 and 3306. These Ports are potentially vulnerable for the following reasons:

Port 22

Port 22 is vulnerable because it is the Secure Shell (SSH) port which enables remote access and file transfer, this is a vulnerability because through remote access it also allows for brute force attacks which is where automated tools can execute thousands of logins attempts through this port.

Potential CVE:

A vulnerability in the Secure Shell (SSH) server code of Cisco IOS Software and Cisco IOS XE Software could allow an authenticated, remote attacker to cause an affected device to reload. The vulnerability is due to an internal state not being represented correctly in the SSH state machine, which leads to an unexpected behaviour. An attacker could exploit this vulnerability by creating an SSH connection to an affected device and using a specific traffic pattern that causes an error condition within that connection. A successful exploit could allow an attacker to cause the device to reload, resulting in a denial of service (DoS) condition.

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:N/I:N/A:H

<https://nvd.nist.gov/vuln/detail/cve-2020-3200>

Port 23

Port 23 is the telnet port which operates the TCP connections that allow for access to switches and routers, the reason this is vulnerable is because of brute force attacks, particularly susceptible to brute force attacks against routers that use default credentials.

Potential CVE:

A security regression (CVE-2006-5051) was discovered in OpenSSH's server (sshd). There is a race condition which can lead sshd to handle some signals in an unsafe manner. An unauthenticated, remote attacker may be able to trigger it by failing to authenticate within a set time period.

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

<https://nvd.nist.gov/vuln/detail/cve-2024-6387>

What should you do?

It is best practice for Port 22 to shut it down if it is not being used so that it cannot be accessed, failing this it would be recommended that a stronger password be implemented for the system and potentially a limit on the amount of passwords that can be attempted at a given time.

Port 443

Port 443 is dangerous because it is a web port (HTTPS) that generally needs to be left open for organizations to operate, however most of the danger lies in the websites that operate on them rather than the actual port itself because while there is an encryption layer that protects the port from attacks, there is no such protections in the web pages unless implemented by the organization itself.

What should you do?

This port generally needs to be kept running because websites will be hosted on it, however should it not be in use it is best to close the port, otherwise implementing website hardening to prevent things like SQL injections or limiting website requests to prevent DDoS attacks would be best practice.

Port 53

Port 53 is the port that handles the domain name system queries and translates domain names into IP addresses for internet traffic. This system is vulnerable because nearly all traffic depends on DNS to function and therefore it is a high value target to attack. One of the common exploits for this port is to send small queries with spoofed source IP to open resolvers, the resolver returns large responses which overwhelm the network in unregulated volumes in a DDoS Attack.

Improper handling of DNS over TCP in Simple DNS Plus v9 allows a remote attacker with querying access to the DNS server to cause the server to return request payloads from other clients. This happens when the TCP length prefix is malformed (len differs from actual packet len), and due to a concurrency/buffering issue, even when the lengths match. A length prefix that is smaller than the actual packet size increases information leakage. In summary, this vulnerability allows an attacker to see DNS queries of other clients.

Base Score: 6.5 **MEDIUM** **Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Port 445 and Port 139

These two ports operate on a similar purpose, port 445 (SMB) was introduced to replace port 139 and 137 (NETBIOS) and are only still available to allow for backwards compatibility in networks that include both network options. The protocol itself allows for file sharing, print sharing, and network communication on the network. Vulnerabilities of this port type are NTLM relay attacks and brute force credential attacks.

Port 3389

Port 3389 handles Remote Desktop Protocol and provides graphical remote access to windows systems. RDP is used in enterprise environments and therefore is susceptible to brute force attacks through open RDP ports with username and password pairs from previous breaches against exposed RDP services.

Potential CVE:

A remote code execution vulnerability exists in Remote Desktop Services – formerly known as Terminal Services – when an unauthenticated attacker connects to the target system using RDP and sends specially crafted requests. This vulnerability is pre-authentication and requires no user interaction. An attacker who successfully exploited this vulnerability could execute arbitrary code on the target system. An attacker could then install programs; view, change, or delete data; or create new accounts with full user rights. To exploit this vulnerability, an attacker would need to send a specially crafted request to the target systems Remote Desktop Service via RDP. The update addresses the vulnerability by correcting how Remote Desktop Services handles connection requests.

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

<https://nvd.nist.gov/vuln/detail/cve-2019-1182>

What should you do?

It is recommended that you close this port because it is not necessary for operation.

Port 3306

Port 3306 is a Microsoft SQL server port, this port provides direct access to database services. This being open means it is exposed and could be accessed through the internet. Common exploitations are brute force attacks which attack the logins leveraging automated tools to make thousands of requests. As well as direct SQL injection as open ports allow for attackers to bypass web application firewalls entirely, allowing for direct SQL injections.

A remote code execution vulnerability exists in Remote Desktop Services – formerly known as Terminal Services – when an unauthenticated attacker connects to the target system using RDP and sends specially crafted requests. This vulnerability is pre-authentication and requires no user interaction. An attacker who successfully exploited this vulnerability could execute arbitrary code on the target system. An attacker could then install programs; view, change, or delete data; or create new accounts with full user rights. To exploit this vulnerability, an attacker would need to send a specially crafted request to the target systems Remote Desktop Service via RDP. The update addresses the vulnerability by correcting how Remote Desktop Services handles connection requests.

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

<https://nvd.nist.gov/vuln/detail/cve-2019-1181>

What should you do?

It is recommended that you close the port or instead route traffic through a secure web page which has been created with Website hardening techniques.

Figure #1 - Table of Hosts and Associated Common Vulnerable Ports.

Hosts	Vulnerable Ports
10.200.198.1	22, 443
10.200.108.8 (DC7.soit.local.)	53, 445, 139, 3389
10.200.108.9 (NET.soit.local)	445, 3389
10.200.108.13	23, 80
10.200.108.15	23, 80
10.200.108.16 (NPS2.soit.local)	3389
10.200.108.17	22
10.200.108.20	22, 80, 443
10.200.108.21	22, 80
10.200.108.22	22, 80, 443
10.200.108.30 (LOTA.soit.local)	3389
10.200.108.41 (PFWDC01.pcsupport.ac.nz)	139, 445, 3389,
10.200.108.44	22, 80, 443
10.200.108.45	22
10.200.108.48 (Dep1.soit.local)	445, 3389
10.200.108.49	22
10.200.108.51 (T7-Lab02.soit.local)	3389
10.200.108.52	
10.200.108.55 (T608.soit.local)	22, 8080
10.200.108.59 (Truenas.local)	80, 443, 445
10.200.108.62 (Winweb.soit.local)	139, 445, 3389, 3306
10.200.108.65	22, 3389, 8080, 3306
10.200.108.66	22, 80, 443
10.200.108.69 (Mit-1.soit.local)	3389
10.200.108.79 (Netroom.soit.local)	445, 3389
10.200.108.80	22, 3389
10.200.108.82	22, 3389
10.200.108.83 (T608-11.soit.local)	22
10.200.108.84 (T608-12.soit.local)	22, 3389
10.200.108.200	3389
10.200.108.241	22, 80, 443

<https://securityscorecard.com/blog/navigating-the-risks-of-tcp-445-strategies-for-secure-network-communication/>